

LAB 05 — NESSUS / APT29 VULNERABILITY CROSSWALK

Mapping Lab 03 Nessus Findings to APT29 ATT&CK; Techniques

CySA+ Home Lab Portfolio | Alejandro W. Orellana | June 24, 2026

Purpose & Methodology

This crosswalk maps the top 8 vulnerabilities discovered during Lab 03 (Nessus scan of Metasploitable2) to APT29 MITRE ATT&CK; techniques from Lab 05. The goal is to answer a practical threat intelligence question: **if APT29 targeted this system, which vulnerabilities would they most likely exploit, and which techniques would those exploits enable?**

This type of analysis — connecting vulnerability data to a specific threat actor profile — is a core function of GRC analysts, threat intelligence teams, and SOC L2/L3 roles. It demonstrates the ability to operationalize threat intelligence rather than treat it as an abstract exercise.

Vulnerability to ATT&CK; Technique Crosswalk

CVE / Plugin ID	Vulnerability	CVSS	ATT&CK; ID	Technique	Tactic	APT29 Rationale
Nessus 201352	Ubuntu 8.04 End-of-Life OS	10.0	T1190	Exploit Public-Facing Application	Initial Access	An EOL OS receives no security patches, leaving all known CVEs permanently unmitigated. APT29 exploits unpatched public-facing systems as a primary initial access vector.
Nessus 61708	VNC Server 'password' Password	10.0	T1078	Valid Accounts	Persistence / Lateral Movement	Default/trivial credentials on VNC give an attacker valid interactive access. APT29 consistently abuses valid accounts to blend into legitimate traffic and avoid detection.
CVE-2020-1745	Apache Tomcat Ghostcat (AJP RCE)	9.8	T1190	Exploit Public-Facing Application	Initial Access	Ghostcat allows unauthenticated file read/inclusion via the AJP connector, enabling RCE on exposed Tomcat instances — a textbook initial access exploit of the type APT29 uses against internet-facing services.
Nessus 20007	SSL v2/v3 Protocol Detected	9.8	T1557	Adversary-in-the-Middle	Credential Access / Collection	SSL 2.0/3.0 are vulnerable to POODLE and DROWN attacks enabling decryption of traffic. APT29 intercepts credentials and session tokens in transit as part of credential harvesting operations.
Nessus 51988	Bind Shell Backdoor Detection	9.8	T1505.003	Server Software Component: Web Shell	Persistence	An active bind shell indicates the system is already compromised or contains a persistent backdoor. APT29 deploys backdoors and web shells as core persistence mechanisms across all major campaigns.
CVE-1999-0651	rlogin Service Detection	7.5	T1021	Remote Services	Lateral Movement	rlogin transmits credentials in cleartext and bypasses modern auth controls. APT29 abuses legacy remote services to move laterally without deploying additional malware.
CVE-2016-2118	Samba Badlock Vulnerability	7.5	T1557	Adversary-in-the-Middle	Credential Access / Collection	Badlock enables MitM attacks against SMB/DCE-RPC sessions, allowing credential interception. APT29 targets authentication protocols to harvest credentials for lateral movement.

CVE / Plugin ID	Vulnerability	CVSS	ATT&CK; ID	Technique	Tactic	APT29 Rationale
Nessus 42256	NFS Shares World Readable	7.5	T1083	File and Directory Discovery	Discovery	World-readable NFS shares expose file system contents to any network host. APT29 conducts file and directory reconnaissance to identify sensitive data and pivot opportunities during post-exploitation.
CRITICAL (CVSS 9.8–10.0)		HIGH (CVSS 7.5–9.7)		* Table repeats on next page if printed		

ATT&CK; Technique Frequency Summary

Five distinct ATT&CK; techniques emerge from the 8 Nessus findings. Two techniques appear multiple times, indicating these are the highest-priority attack surfaces on this host from an APT29 perspective.

ATT&CK; ID	Technique	Tactic	# Vulns	Mapped Vulnerabilities
T1190	Exploit Public-Facing Application	Initial Access	2	Ubuntu EOL OS (10.0); Apache Ghostcat (9.8)
T1557	Adversary-in-the-Middle	Credential Access	2	SSL v2/v3 (9.8); Samba Badlock (7.5)
T1078	Valid Accounts	Persistence / Lateral Movement	1	VNC Default Password (10.0)
T1505.003	Web Shell / Backdoor	Persistence	1	Bind Shell Backdoor (9.8)
T1021	Remote Services	Lateral Movement	1	rlogin Service (7.5)
T1083	File and Directory Discovery	Discovery	1	NFS World-Readable Shares (7.5)

Analyst Findings & Risk Narrative

- Highest APT29 Risk — Initial Access (T1190):** Two findings map to T1190: the EOL operating system (which leaves all future CVEs permanently unpatched) and Ghostcat (CVE-2020-1745, CVSS 9.8). An EOL OS is not a single vulnerability — it is an ongoing condition of total unmitigated exposure. APT29 specifically targets unpatched internet-facing services as primary entry points, making these two findings the most critical to remediate first.
- Credential Exposure — Valid Accounts (T1078):** The VNC default password finding (CVSS 10.0) gives an attacker authenticated interactive access with zero exploitation complexity. APT29’s core tradecraft relies on valid credential use to blend with legitimate activity and avoid endpoint detection — this finding directly enables that technique.
- Pre-Existing Compromise — Bind Shell (T1505.003):** The bind shell backdoor finding is categorically different from the others: it indicates the system may already be compromised. This is not a potential attack path — it is a confirmed persistence mechanism. In a real environment this would trigger an immediate incident response process, not a patch cycle.
- Protocol-Level Weakness — MitM (T1557):** Both SSL v2/v3 and Samba Badlock map to T1557, enabling credential interception in transit. These findings compound the credential risk from T1078 — an attacker who can intercept network traffic has multiple paths to harvest credentials without ever touching an endpoint.
- Lab 04 Continuity — T1078 Observed in BOTSv1:** T1078 (Valid Accounts) was independently confirmed as an active technique in the Lab 04 BOTSv1 investigation, where both the joomla service account and bob.smith/WAYNECORPINC were abused. The Nessus findings show why: default and weak credentials create the exact conditions APT29 exploits in real campaigns.

Key Takeaway: This host presents APT29 with a complete attack chain — Initial Access via T1190 (unpatched services), Persistence via T1078 and T1505.003 (valid credentials + backdoor), lateral movement via T1021 (rlogin), credential harvesting via T1557 (MitM), and discovery via T1083 (NFS enumeration). Remediating the CVSS 10.0 findings (EOL OS, VNC password) eliminates the two highest-probability initial access and persistence vectors.

Remediation Priority Order (APT29 Risk-Adjusted)

Standard CVSS-order remediation and APT29-adjusted order differ on one key point: the Bind Shell Backdoor moves to Priority 1 in a threat-informed context because it indicates active or prior compromise — all other remediation is secondary until the system's integrity is verified.

Priority	Finding	CVSS	Reason for Ranking
1 — IMMEDIATE	Bind Shell Backdoor	9.8	Potential active compromise. IR process required before any other remediation.
2 — CRITICAL	Ubuntu 8.04 EOL OS	10.0	Permanent unmitigated exposure. All future CVEs unpatched. Rebuild or upgrade.
3 — CRITICAL	VNC Default Password	10.0	Trivial credential enables T1078 — APT29's core persistence technique.
4 — CRITICAL	Ghostcat (CVE-2020-1745)	9.8	Unauthenticated RCE via AJP. Patch Tomcat or disable AJP connector.
5 — CRITICAL	SSL v2/v3 Detected	9.8	Enables T1557 MitM. Disable legacy SSL; enforce TLS 1.2+.
6 — HIGH	Samba Badlock (CVE-2016-2118)	7.5	Compounds T1557 risk. Upgrade Samba to 4.4.2+.
7 — HIGH	rlogin Service	7.5	Cleartext credentials; enables T1021 lateral movement. Replace with SSH.
8 — HIGH	NFS World-Readable Shares	7.5	Enables T1083 discovery. Restrict NFS exports to specific hosts/UIDs.